

Narrativa explicativa del marco GQM + PRAGMATIC para indicadores HyVAW

Una de las tragedias discretas de la medición en ciberseguridad es que podemos ahogarnos en números y seguir sin saber si estamos mejor o peor que ayer. HyVAW aporta un flujo razonablemente elegante para analizar vulnerabilidades en sistemas complejos; NIS2 obliga a hacerlo bien y a demostrarlo; GQM y PRAGMATIC nos ayudan a que los indicadores no se conviertan en arte abstracto.[web:3][web:16][web:23][web:36][web:43][web:48]

El enfoque GQM nos recuerda una obviedad que conviene repetir: primero se fijan metas, luego se formulan preguntas, y solo entonces se definen métricas.[web:43][web:45] En el contexto nacional español, las metas son bastante claras: cubrir más sistemas esenciales con análisis híbridos serios, mejorar la calidad de esos análisis, reducir el riesgo operativo y justificar que el dinero invertido en todo esto no se ha escapado por la ventana.[web:18][web:23][web:32][web:36]

A partir de esas metas, el informe HyVAW nos ofrece material abundante para formular preguntas: ¿qué porcentaje de sistemas esenciales pasan por un flujo híbrido al menos una vez al año?, ¿cuánto tardamos en remediar vulnerabilidades críticas?, ¿cuántos incidentes graves vienen de vulnerabilidades que ya conocíamos?, ¿cuánto cuesta todo esto y qué estamos evitando exactamente?[web:3][web:8][web:19][web:32] Cada una de esas preguntas se traduce en métricas específicas, operacionalizables y, con un poco de disciplina, comparables entre sectores y países.

Ahora bien, no toda métrica es igual de digna. Ahí entra PRAGMATIC, ese acrónimo feliz que nos exige preguntarnos si cada indicador es predictivo, relevante, accionable, genuino, significativo, preciso, oportuno, independiente y razonablemente barato de obtener.[web:42][web:44][web:48] Descubrimos que algunas métricas brillan (el tiempo medio de remediación de vulnerabilidades críticas, la proporción de incidentes causados por vulnerabilidades conocidas), mientras que otras son más bien tímidas (el ROI financiero exacto de HyVAW, por ejemplo, que vive rodeado de supuestos).

El resultado de cruzar GQM con PRAGMATIC es un catálogo de métricas HyVAW-NIS2 que no pretende ser exhaustivo, sino útil. No se mide todo lo que se mueve; se mide lo que responde a metas claras y supera un mínimo de dignidad PRAGMATIC.[web:43][web:48] El índice de cobertura de sistemas analizados híbridamente, la tasa de falsos positivos críticos, el cumplimiento de plazos de remediación y la proporción de incidentes por vulnerabilidad conocida forman el corazón del cuadro de mando. Métricas de coste y ROI se mantienen, pero en un nivel más interpretativo, con advertencia de “manejar con guantes”.

Esta narrativa no sustituye a las tablas, pero les da contexto. Ayuda a explicar a un CISO, a un regulador o a un miembro del Consejo por qué insistimos en determinados números y no en otros, y por qué es mejor tener pocas métricas sólidas que cincuenta indicadores brillantes pero vacíos. La idea es sencilla: que cada cifra HyVAW que aparezca en un informe nacional pueda seguir su linaje hasta una meta estratégica y superar, sin sonrojarse, el examen PRAGMATIC.